

Q Do you think state governments need to target security to avoid instances of Heartbleed, Shellshock and POODLE, in the future?

I think having a clear cyber-resilience strategy is an imperative role for every government, not only to protect critical infrastructure but also to protect the privacy of its citizens. My concern is that politicians are not fit to make a decent decision in this field. And because politicians are not experts, they hire consultants who are more focused on prolonging the problems to make more money. The Open Source Movement is the proper answer.

Open standards like the OSSTMM are made without the conflict of interest which we see with organisations like ISO, AXELLOS, ISACA or the (ISC). The latter focus more on the money-making side of standards and certifications, instead of working together to make things right.

Q How is Fedora Security Lab different from other similar pentest distros such as Kali Linux and Back Box?

I have not really looked into the other distros so I might be wrong in my answer, but the difference could be that we are an RPM-based distro. We also focus on testing methodologies, and on teaching along with a test-bench that provides vulnerable services and applications for testing purposes.

We have a fast pace with the Fedora project release cycle of six months, which might also be a difference. I see the FSL more as a starting point to build your own RPM-based security testing platform than a simple pentest distro.

Q Apart from offering Fedora Security Lab, you also teach Fedora Security and the Open Source Security Testing Methodology Manual (OSSTMM). How easy is it to educate people about concepts like penetration testing and security assessment?

The OSSTMM breaks with a lot of conventional security thinking. It is a scientific approach and, for several people, it is not easy to accept a new truth, at first. As soon as the practicability of the OSSTMM is demonstrated and you start using it in your daily work, you see the proper test results and you understand how it helps to become a much better security tester or security analyst.

In my opinion, it is easy to teach in regions like India because people are hungry for knowledge. But teaching security practices is also challenging, because people will not accept methodologies that do not work for them.

Q Considering the present job scenario in the IT industry, what is your opinion about security testing as a career?

It is awesome to have a career in security testing, but before you learn how to destroy or manipulate something, you should learn how to build and maintain it first. It is much harder to maintain a secure infrastructure than to find a flaw in this infrastructure. So the admins

“ I consider myself a part of the Indian null security community and the Fedora community. ”

who are able to maintain a secure environment are the real super heroes.

Q Why should enterprises nowadays focus more on security rather than on expanding their existing operations?

The operational business will always come first, but operational security is the vital part of keeping it running.

Unfortunately, in my experience, what enterprises invest in security analysis is often not even one per cent of their revenue. Instead, entrepreneurs invest in more security solutions: “Yeah, just let us buy another firewall or IDS.” Enterprises that focus more on cyber security than on other security channels are making a mistake.

With the exploding number of breach of trusts that we have from different security channels, a security strategy needs to consider all these new vectors and figure out how to measure them and make the process transparent. Even today, I believe the easiest and most successful way to breach security is through the human channel (social engineering).

Another mistake is to rely on compliance and standards too much. While compliance assures average quality and security standards, which is good, it can also be a threat that can disable the operational business from one day to another. Being compliant does not mean you are secure, and being secure does not necessarily mean that you are complying with the required regulations or standards either.

Q Lastly, how has the field of penetration testing and security assessment evolved in the recent past?

I think the security communities have become more professional, which is good and bad at the same time. You end up with conflicting pressures of having fun, being a proper tester or making money.

What concerns me a bit is the trend of external bug bounty programmes run by big vendors that are very popular in India. Some might see this as an evolution. In my opinion, bug bounties are a bad way to deal with security and with people. It focuses on the limitations, and you get paid only if you find a bug. And corporates even save money by outsourcing these programmes — partnering with bug bounty brokers or coordinators.

I want to cite my mentor Pete Herzog here: “In street economics, it is just called pimping.” This means proper and complete testing is considered not worth paying for anymore. I am convinced that if this trend becomes increasingly successful, and if more and more follow this model, the payments will break down, and the quality of limitations found will get worse. That, of course, is bad for security. 